

Curso de ciberseguridad

Apuntes teóricos y glosarios

Elaborado y redactado por: Lihúén Villarreal

Índice de contenidos

Sistemas operativos (OS).....	4
Boot (secuencia de arranque).....	4
CLI (Command Line Interface).....	4
GUI (Graphical User Interface).....	4
Linux.....	4
Unix.....	4
GNU.....	4
Kernel.....	5
Distribuciones (distros).....	5
Arquitectura.....	5
Usuario.....	5
Super usuario (root user).....	5
Aplicaciones.....	5
Paquetes.....	5
Shell.....	6
Comandos Bash.....	6
Permisos.....	8
FHS (Filesystem Hierarchy Standard).....	9
Directorios estándar.....	9
Rutas de archivo.....	9
Kernel.....	10
Hardware.....	10
Dispositivos periféricos.....	10
Hardware interno.....	10
Redes.....	10
Arquitectura de redes.....	10
LAN (Local Area Network).....	10
WAN (Wide Area Network).....	10
Hub.....	11
Switch.....	11
Router.....	11
Modem.....	11
Setups.....	11
Ethernet.....	12
WiFi.....	12
Comunicación entre redes.....	12

Puertos.....	12
Protocolos.....	13
Segmentación de redes.....	14
Zonas de seguridad.....	14
Firewalls.....	14
VPN (Virtual Private Network).....	14
Servidores Proxy.....	14
Glosario de redes.....	15
Amenazas y ataques.....	16
Malware.....	16
Virus.....	16
Worm (Gusano).....	16
Trojan (Troyano).....	16
Ransomware.....	16
Spyware.....	16
Keylogger.....	16
Adware.....	16
Ataques.....	16
Ingeniería social (social engineering).....	16
Phishing.....	17
Brute Force Attack.....	17
Ataques de inyección.....	17
Inyección SQL (SQLi).....	17
XSS (Cross-Site Scripting).....	18
Cryptojacking.....	18
Suplantación de IP (IP Spoofing).....	19
Denial of Service (DoS).....	19
SYN flood.....	19
Smurf attack.....	19
Packet Sniffing.....	20
Man-in-the-Middle (MitM).....	20
Glosario de amenazas y ataques.....	20
Ciberseguridad.....	22
Activos (Assets).....	22
Datos.....	22
PII (Personally Identifiable Information).....	22
SPII (Sensitive Personally Identifiable Information).....	22
Packets.....	22
Autenticación.....	23
CAPTCHA.....	23
Criptografía.....	23
Cifrado.....	24
Claves.....	24
Hashing.....	24
Servicios en la nube (Cloud-based services).....	24

Software as a Service (SaaS).....	25
Platform as a Service (PaaS).....	25
Infrastructure as a Service (IaaS).....	25
Máquinas virtuales (VMs).....	25
Hypervisors.....	25
SIEM (Security Information and Event Management).....	25
Logs.....	26
Evento vs. Incidente.....	26
Detección y respuesta (incidentes).....	26
Categorías de detección.....	27
Documentación.....	27
Glosario de ciberseguridad.....	27
Lenguajes de programación en ciberseguridad.....	31
SQL.....	31
JavaScript.....	31
Python.....	33

Sistemas operativos (OS)

Son el software que gestiona los recursos del hardware para ejecutar programas, aplicaciones y procesos en simultáneo, y permite la interacción del usuario con la computadora.

Boot (secuencia de arranque)

Al encender la computadora, se activa un microchip BIOS o UEFI.

El **BIOS (Basic Input/Output System)** es un microchip que contiene instrucciones de arranque y es común en sistemas más antiguos (fue estándar hasta 2007).

El **UEFI (Unified Extensible Firmware Interface)** es un microchip que también contiene instrucciones de arranque y reemplaza al BIOS en sistemas más modernos, ya que ofrece mejoras en seguridad.

Las instrucciones de arranque incluyen verificar el estado del hardware del sistema. La última instrucción activa el **bootloader**, un programa que inicia el sistema operativo.

CLI (Command Line Interface)

Interfaz donde el usuario solo puede interactuar escribiendo comandos de texto.

GUI (Graphical User Interface)

Interfaz visual con ventanas, íconos y botones.

Linux

- Sistema operativo **libre y de código abierto**.
- Desarrollado por Linus Torvalds en 1991 (kernel y OS).
- Basado en Unix, mantiene compatibilidad con sus estándares.
- Incluye componentes del proyecto GNU (herramientas y utilidades esenciales como shell, compiladores y bibliotecas).

Unix

- Sistema operativo creado en los años 70.
- Estable, multitarea y multiusuario.
- Sirvió de base conceptual para muchos sistemas modernos, incluido Linux.
- Características clave: jerarquía de archivos, procesos independientes, herramientas pequeñas que se combinan.

GNU

- Proyecto GNU ("GNU's Not Unix"), iniciado por Richard Stallman en 1983.
- Objetivo: crear un sistema operativo libre compatible con Unix.

- Proporciona herramientas y utilidades esenciales (shell, compiladores, bibliotecas), pero no el kernel.

Kernel

- Núcleo del sistema operativo.
- Administra el hardware y los recursos del sistema (CPU, memoria, dispositivos y procesos) para que puedan ser utilizados por el software.

Distribuciones (distros)

- Versiones de Linux empaquetadas con kernel, software GNU, utilidades y gestor de paquetes.
- Cada distro puede orientarse a ser más estable, ligera o amigable para usuarios.
- Ejemplos: Ubuntu, Fedora, Debian.

Arquitectura

Usuario

Es la persona que interactúa con una computadora. Inicia y gestiona tareas en el sistema. Linux es un sistema **multiusuario**, lo que significa que varios usuarios pueden usar los mismos recursos al mismo tiempo.

Tipos de usuarios:

- **Owner** → propietario del archivo
- **Group** → grupo al que pertenece el archivo
- **Others** → todos los demás usuarios

Super usuario (root user)

Administrador o usuario con máximo privilegio en Linux.

Puede instalar programas, cambiar configuraciones del sistema y acceder a todos los archivos.

El comando **sudo** (super-user-do) de la shell asigna temporalmente privilegios de super usuario a un usuario específico.

Aplicaciones

Son programas que realizan tareas específicas.

Algunas vienen **preinstaladas** (calculadoras, calendarios), otras deben instalarse (navegadores, clientes de correo).

Paquetes

En Linux, normalmente se usa un **gestor de paquetes** para instalar aplicaciones.

Un **paquete** es un software que puede combinarse con otros paquetes para formar una aplicación completa.

Shell

La shell es el **intérprete de línea de comandos**, que permite al usuario dar comandos al kernel y recibir respuestas, únicamente ingresando texto.

Tipos principales:

- **Bash (Bourne Again Shell):** Shell más común en Linux, compatible con scripts y comandos de Bourne Shell. Soporta historial de comandos, autocompletado y scripting avanzado.
- **Sh (Bourne Shell):** Shell original de Unix. Básico, portable y eficiente para scripting, pero con menos funciones interactivas que Bash.
- **Csh (C Shell):** Sintaxis similar al lenguaje C. Incluye historial de comandos y alias. Popular para scripts orientados a programación tipo C.
- **Ksh (Korn Shell):** Combina características de Bourne y C Shell. Soporta scripting avanzado y funciones interactivas.
- **Zsh (Z Shell):** Shell moderno con funciones avanzadas: autocompletado, historial inteligente y personalización. Muy popular en distribuciones modernas.

Conceptos clave:

- **Standard Input (stdin):** Datos que la shell o un programa recibe para procesar.
- **Standard Output (stdout):** Datos que la shell o un programa retorna como resultado de un comando.
- **Standard Error (stderr):** Mensajes que indican problemas o fallos al ejecutar un comando.
- **Comando:** Instrucción que se escribe en la shell para que ejecute una acción.
- **Argumentos:** Información adicional que se agrega a un comando para modificar su comportamiento.
- **Prompt:** Símbolo o texto que indica que la shell está lista para recibir comandos.

Comandos Bash

Comando	Qué hace
ls	Lista archivos y directorios del directorio actual
cd	Cambia de directorio
pwd	Muestra la ruta del directorio actual

<code>mkdir</code>	Crea un nuevo directorio
<code>rmdir</code>	Elimina un directorio vacío
<code>rm</code>	Elimina archivos o directorios
<code>cp</code>	Copia archivos o directorios
<code>mv</code>	Mueve o renombra archivos o directorios
<code>touch</code>	Crea un archivo vacío o actualiza su fecha
<code>cat</code>	Muestra el contenido de un archivo
<code>less</code>	Muestra el contenido de un archivo página por página
<code>more</code>	Muestra el contenido de un archivo de forma paginada (más simple que <code>less</code>)
<code>head</code>	Muestra las primeras líneas de un archivo
<code>tail</code>	Muestra las últimas líneas de un archivo
<code>echo</code>	Muestra texto en la terminal
<code>man</code>	Muestra el manual de un comando
<code>whoami</code>	Muestra el usuario actual
<code>id</code>	Muestra información del usuario y sus grupos
<code>chmod</code>	Cambia permisos de archivos o directorios
<code>chown</code>	Cambia propietario de archivos o directorios
<code>df</code>	Muestra espacio libre y usado en los sistemas de archivos
<code>du</code>	Muestra el tamaño de archivos y directorios
<code>find</code>	Busca archivos o directorios según criterios
<code>grep</code>	Busca texto dentro de archivos
<code>ps</code>	Muestra procesos en ejecución
<code>top</code>	Muestra procesos en ejecución en tiempo real
<code>kill</code>	Finaliza procesos por su ID
<code>ping</code>	Verifica conectividad con otro host
<code>wget</code>	Descarga archivos desde internet
<code>curl</code>	Transfiere datos desde o hacia un servidor
<code>tar</code>	Comprime o descomprime archivos en formato tar
<code>gzip</code>	Comprime archivos en formato gzip
<code>gunzip</code>	Descomprime archivos gzip
<code>zip</code>	Comprime archivos en formato zip
<code>unzip</code>	Descomprime archivos zip
<code>ssh</code>	Conecta a otra máquina de forma segura
<code>scp</code>	Copia archivos entre máquinas usando SSH

<code>history</code>	Muestra comandos usados anteriormente
<code>alias</code>	Crea un alias para un comando
<code>unalias</code>	Elimina un alias
<code>env</code>	Muestra variables de entorno
<code>export</code>	Define o modifica variables de entorno
<code>clear</code>	Limpia la pantalla de la terminal
<code>uptime</code>	Muestra cuánto tiempo lleva encendida la computadora
<code>date</code>	Muestra o cambia la fecha y hora
<code>who</code>	Muestra usuarios conectados
<code>uname</code>	Muestra información del sistema
<code>df -h</code>	Muestra espacio en disco de manera legible (humano)
<code>diff</code>	Compara el contenido de dos archivos
<code>cmp</code>	Compara archivos byte a byte
<code>file</code>	Muestra el tipo de archivo
<code>stat</code>	Muestra información detallada de un archivo
<code>mount</code>	Monta un dispositivo de almacenamiento
<code>umount</code>	Desmonta un dispositivo de almacenamiento
<code>jobs</code>	Muestra procesos en segundo plano de la sesión actual
<code>bg</code>	Reanuda un trabajo en segundo plano
<code>fg</code>	Trae un trabajo al primer plano
<code>sudo</code>	Ejecuta un comando como superusuario
<code>nano</code>	Editor de texto básico en terminal
<code>vi / vim</code>	Editor de texto avanzado en terminal
<code>cut</code>	Extrae columnas o partes de un archivo de texto
<code>sort</code>	Ordena líneas de un archivo de texto
<code>uniq</code>	Elimina líneas repetidas consecutivas
<code>wc</code>	Cuenta líneas, palabras y caracteres de un archivo
<code>head -n / tail -n</code>	Muestra un número específico de líneas desde el inicio o final
<code>tr</code>	Transforma o reemplaza caracteres de un archivo o texto
<code>xargs</code>	Construye y ejecuta comandos a partir de entrada estándar
<code>tee</code>	Copia la salida de un comando a un archivo y la muestra en pantalla
<code>alias</code>	Crea un nombre corto para un comando largo

Permisos

- **r** → **read** → permiso de lectura

- **w** → **write** → permiso de escritura
- **x** → **execute** → permiso de ejecución

Tipos de usuarios:

- **u** → **Owner** → propietario del archivo
- **g** → **Group** → grupo al que pertenece el archivo
- **o** → **Others** → todos los demás usuarios

Los permisos se listan como un **string** de 10 caracteres: **drwxrwxrwx**.

1. **d / -** → tipo de archivo (d → directorio / - → archivo regular)
2. **r / -** → permiso de lectura para el propietario (d → sí / - → no)
3. **w / -** → permiso de escritura para el propietario (d → sí / - → no)
4. **x / -** → permiso de ejecución para el propietario (d → sí / - → no)
5. **r / -** → permiso de lectura para el grupo (d → sí / - → no)
6. **w / -** → permiso de escritura para el grupo (d → sí / - → no)
7. **x / -** → permiso de ejecución para el grupo (d → sí / - → no)
8. **r / -** → permiso de lectura para otros (d → sí / - → no)
9. **w / -** → permiso de escritura para otros (d → sí / - → no)
10. **x / -** → permiso de ejecución para otros (d → sí / - → no)

FHS (Filesystem Hierarchy Standard)

Un **directorio** (o “carpeta”) contiene archivos u otros directorios.

El FHS define cómo se organizan los directorios y datos, y dónde se almacenan dentro del sistema operativo.

Directorios estándar

- **Root (/):** Directorio raíz, donde se encuentran todos los demás directorios en Linux.
- **/home:** Directorio personal de cada usuario del sistema.
- **/bin:** (“binary”) Directorio de archivos binarios y ejecutables (archivos que contienen una serie de comandos que la computadora sigue para ejecutar programas y realizar funciones).
- **/etc:** Directorio que almacena los archivos de configuración del sistema.
- **/tmp:** Directorio que guarda archivos temporales. Es usado frecuentemente por atacantes, porque cualquier usuario del sistema puede modificar los datos de estos archivos.
- **/mnt:** (“mount”) Directorio que almacena medios externos, como unidades USB y discos duros.

Rutas de archivo

- **Absolute file path – Ruta de archivo absoluta:**
La ruta completa de un archivo, que comienza desde la raíz (/).

- **Relative file path – Ruta de archivo relativa:**

Ruta de un archivo que comienza desde el directorio actual del usuario.

Kernel

Asigna recursos y controla las funciones principales del hardware.

Hardware

Componentes físicos de la computadora.

Dispositivos periféricos

Componentes conectados y controlados por el sistema, pero **no esenciales** para su funcionamiento. Se pueden agregar o quitar libremente.

Ejemplos: monitores, impresoras, teclado, ratón.

Hardware interno

Componentes esenciales para que la computadora funcione.

Incluye la **placa base (motherboard)** y todos los componentes conectados a ella:

- **CPU (Central Processing Unit):** Procesador principal que ejecuta instrucciones de los programas.
- **RAM (Random Access Memory):** Memoria de corto plazo; almacena datos temporalmente mientras se realizan tareas. Los datos se borran al apagar la computadora.
- **Disco duro:** Memoria de largo plazo; almacena programas y archivos de forma permanente, accesible incluso después de apagar y encender la computadora. Una computadora puede tener varios discos duros.

Redes

Arquitectura de redes

LAN (Local Area Network)

→ **Red de área local.**

Conecta dispositivos en un espacio pequeño: casa, oficina, edificio.

Es rápida, privada y de corto alcance.

Ejemplo: WiFi del hogar.

WAN (Wide Area Network)

→ **Red de área amplia.**

Conecta redes LAN entre sí a grandes distancias.

Es global, más compleja y generalmente más lenta que una LAN.

Ejemplo: Internet.

Hub

→ **Concentrador.**

Dispositivo muy básico que recibe datos y los envía a todos los dispositivos conectados, sin filtrar.

Hoy está prácticamente en desuso, porque genera tráfico innecesario y es inseguro.

Switch

→ **Conmutador.**

Más inteligente que el hub.

Envía los datos solo al dispositivo correcto.

Mejora velocidad, eficiencia y seguridad dentro de una LAN.

Router

→ **Enrutador.**

Conecta diferentes redes (por ejemplo, una LAN con Internet).

Decide por dónde enviar los datos.

Es el “director de tráfico” entre redes.

Modem

→ O **módem**, castellanizado.

Convierte la señal del proveedor de Internet a algo que una LAN pueda usar.

Por ejemplo: señal de cable/fibra → datos digitales.

Setups

En el hogar, el **modem-router** es un solo aparato que contiene tanto el modem (que conecta a internet), el router (que divide Internet entre los dispositivos) y el switch (que dirige los datos de la red a los dispositivos).

El router sería como “las calles” que conectan el dispositivo con la red, y el switch sería como “el semáforo” que indica para dónde van los datos en tiempo real durante el uso/actividad.

En organizaciones a mayor escala, el modem, router/s y switches son dispositivos separados para mayor eficiencia, control y seguridad.

Ethernet

Tecnología de **red por cable** para LAN.

Usa direcciones MAC para identificar dispositivos.

Más rápida, estable y segura que WiFi, pero con movilidad limitada.

WiFi

Tecnología de **red inalámbrica** para LAN.

Usa ondas de radio para transmitir datos.

Permite movilidad, pero es más susceptible a interferencias, fluctuaciones e interceptaciones.

Comunicación entre redes

- **TCP/IP Model:** modelo de comunicación que describe cómo viajan los datos por una red.
- **Dirección IP:** número que identifica un dispositivo en una red.
- **Dirección MAC:** código identificador físico único de la tarjeta de red.
- **Port (puerto):** son como “puertas” dentro de un dispositivo, que permiten que múltiples servicios funcionen al mismo tiempo.
- **DNS (Domain Name System):** traduce nombres a IPs (por ejemplo, una dirección web consultada).
- **Firewall (cortafuegos):** filtra tráfico de red, decide qué datos entran o salen.

Puertos

En redes, un puerto identifica el **servicio o aplicación** dentro de un dispositivo. Es una ubicación lógica basada en software que organiza el envío y recepción de datos entre dispositivos en una red.

Se numeran del **0 al 65535**, pero algunos son estándar.

Tipos de puertos:

- **Well-known ports (0–1023)** → estándar, conocidos por servicios comunes.
- **Registered ports (1024–49151)** → aplicaciones específicas.
- **Dynamic/private (49152–65535)** → asignados dinámicamente para conexiones temporales.

Puertos más relevantes y su uso:

Puerto	Protocolo	Uso principal
20 / 21	FTP	Transferencia de archivos
22	SSH	Conexión remota segura
23	Telnet	Conexión remota (no segura)
25	SMTP	Envío de emails
53	DNS	Resolución de nombres de dominio
67 / 68	DHCP	Asignación automática de IP
80	HTTP	Web sin cifrado
443	HTTPS	Web segura (cifrada)
110	POP3	Recepción de emails
143	IMAP	Recepción de emails
3389	RDP	Escritorio remoto Windows

Protocolos

Protocolo	Significado	Uso
HTTP	Hypertext Transfer Protocol	Permite la transferencia de páginas web sin cifrado.
HTTPS	Hypertext Transfer Protocol Secure	Igual que HTTP, pero con cifrado seguro (TLS/SSL).
FTP	File Transfer Protocol	Transferencia de archivos entre dispositivos.
SFTP	SSH File Transfer Protocol	Transferencia de archivos segura a través de SSH.
SMTP	Simple Mail Transfer Protocol	Envío de correos electrónicos.
POP3	Post Office Protocol version 3	Recepción de correos electrónicos, descarga al dispositivo.
IMAP	Internet Message Access Protocol	Recepción de correos, mantiene sincronización en servidor.
DNS	Domain Name System	Traduce nombres de dominio a direcciones IP.
DHCP	Dynamic Host Configuration Protocol	Asigna automáticamente direcciones IP y configuración de red.
TCP	Transmission Control Protocol	Establece conexión confiable entre dispositivos para enviar datos.
UDP	User Datagram Protocol	Envía datos sin conexión ni garantía de entrega, más rápido.
ARP	Address Resolution Protocol	Traduce direcciones IP a direcciones MAC dentro de la LAN.
ICMP	Internet Control Message Protocol	Envía mensajes de control, como "ping" y errores de red.
SSH	Secure Shell	Conexión remota segura a otro dispositivo.
Telnet	Telecommunication Network	Conexión remota no segura (hoy casi obsoleta).
RDP	Remote Desktop Protocol	Permite controlar un escritorio remoto Windows.
SNMP	Simple Network Management Protocol	Monitoreo y gestión de dispositivos de red.
NTP	Network Time Protocol	Sincroniza el reloj de los dispositivos en la red.

Segmentación de redes

La segmentación de red (network segmentation) es una técnica de seguridad que divide la red en **subredes** (subnetting) separadas para limitar el acceso y mejorar el control.

Zonas de seguridad

Son segmentos de la red definidos según su nivel de confianza para proteger recursos internos y controlar el acceso.

- **Zona no controlada (untrusted / external):** Redes externas (ej: Internet). Bajo nivel de confianza.
- **Zona controlada (trusted / internal):** Red interna de la organización. Alto nivel de confianza.
- **Zona desmilitarizada (DMZ):** Subred intermedia entre la red interna e Internet donde se ubican servicios públicos (web, mail). Aísla la red interna.
- **Zona restringida (restricted / high-security):** Segmento con acceso altamente limitado para datos o sistemas críticos (ej: servidores sensibles).

Firewalls

Son dispositivos (software o hardware) de seguridad que monitorean y filtran el tráfico entre redes o segmentos. Permiten o bloquean ciertos puertos (**port filtering**) para controlar servicios o limitar comunicaciones no deseadas.

Tipos:

- **Stateful (con seguimiento de estado):** Mantiene información sobre conexiones y filtra amenazas de forma proactiva.
- **Stateless (sin seguimiento de estado):** Opera solo con reglas predefinidas, sin seguimiento de estado.

VPN (Virtual Private Network)

Servicio de seguridad de red que **cambia la dirección IP pública y oculta la ubicación virtual**, permitiendo mantener los datos privados al usar redes públicas como internet.

- **Encapsulation – Encapsulación:**
Proceso realizado por un servicio VPN que protege los datos cifrando y envolviendo información sensible en otros paquetes de datos.

Servidores Proxy

Servidores que cumplen las **solicitudes** de los clientes reenviándolas a otros servidores. Son intermediarios entre un usuario y la web. Filtran, regulan y controlan el tráfico y acceso. Proveen seguridad, anonimato y optimización a las redes.

Tipos:

- **Directo (Forward):** Regula el acceso de los usuarios hacia internet.
- **Inverso (Reverse):** Regula el acceso de internet hacia servidores internos.

Glosario de redes

- **Bandwidth – Ancho de banda:**
La capacidad máxima de transmisión de datos en una red, medida en bits por segundo.
- **Data packet – Paquete de datos:**
La unidad básica de información que viaja de un dispositivo a otro dentro de una red.
- **Encapsulation – Encapsulación:**
Proceso realizado por un servicio VPN que protege los datos envolviendo información sensible en otros paquetes de datos.
- **IEEE 802.11 (Wi-Fi) – Estándares Wi-Fi:**
Conjunto de estándares que definen la comunicación para redes LAN inalámbricas.
- **Internet Protocol (IP) – Protocolo de Internet:**
Un conjunto de estándares utilizados para enrutar y direccionar paquetes de datos mientras viajan entre dispositivos en una red.
- **Internet Protocol (IP) address – Dirección IP:**
Una cadena única de caracteres que identifica la ubicación de un dispositivo en internet.
- **Media Access Control (MAC) address – Dirección MAC:**
Un identificador alfanumérico único asignado a cada dispositivo físico en una red.
- **Open Systems Interconnection (OSI) model – Modelo OSI:**
Un modelo estandarizado que describe las siete capas que usan las computadoras para comunicarse y enviar datos a través de una red.
- **Speed – Velocidad:**
La tasa a la que un dispositivo envía y recibe datos, medida en bits por segundo.
- **Subnetting – Subneteo / Subredes:**
Subdivisión de una red en grupos lógicos llamados subredes.
- **TCP/IP model – Modelo TCP/IP:**
Un marco conceptual utilizado para visualizar cómo se organizan y transmiten los datos a través de una red.
- **Wi-Fi Protected Access (WPA) – Acceso Protegido Wi-Fi:**
Protocolo de seguridad inalámbrica para que los dispositivos se conecten a internet.

Amenazas y ataques

Malware

Es cualquier **software malicioso** diseñado para dañar, espiar o acceder sin permiso.

Virus

Código malicioso que se adhiere a archivos o programas y se replica cuando se ejecutan.

Requiere ser ejecutado y se propaga infectando otros archivos.

Worm (Gusano)

Malware que **se propaga solo por la red**.

No requiere ser ejecutado manualmente.

Trojan (Troyano)

Malware que **se hace pasar por algo legítimo**.

No se replica solo, requiere ser instalado.

Ransomware

Malware que **secuestra información** (la cifra) y pide dinero para liberarla.

Spyware

Malware que **espía actividad** (teclado, contraseñas, etc.).

Keylogger

Spyware que **registra lo que se escribe** en el teclado.

Adware

Muestra publicidad intrusiva (a veces con fines maliciosos).

Ataques

Ingeniería social (social engineering)

Manipulación psicológica para que una persona haga algo inseguro.

La forma más popular es el **phishing**.

Además del phishing, incluye:

- **Pretexting (Pretexto):** el atacante inventa una historia creíble para obtener información (ej. "soy de soporte técnico").

- **Baiting (Cebo):** se ofrece algo atractivo (USB, descarga, premio) para que la víctima caiga.
- **Quid pro quo (Intercambio):** se promete un beneficio a cambio de información (ej. “te ayudo con esto si me das tu contraseña”).
- **Tailgating / Piggybacking (Acceso por seguimiento):** entrar a un lugar restringido siguiendo a alguien autorizado.
- **Shoulder surfing (Espionaje visual):** observar directamente lo que alguien escribe o ve (contraseñas, datos).
- **Scareware (Software de miedo):** mensajes alarmantes falsos para que el usuario actúe rápido (ej. “tu PC está infectada”).

Phishing

Técnica de **engaño** para que la víctima entregue información (contraseñas, datos, etc.).

Tipos:

- **Phishing (Suplantación por email):** mensajes fraudulentos que buscan que una persona revele datos o haga clic en enlaces maliciosos.
- **Spear phishing (Phishing dirigido):** versión personalizada para una persona o empresa específica.
- **Whaling (Phishing a altos cargos):** dirigido a ejecutivos o personas con alto nivel de acceso.
- **Vishing (Phishing por voz):** llamadas telefónicas para engañar y obtener información.
- **Smishing (Phishing por SMS):** mensajes de texto fraudulentos con enlaces o pedidos de datos.

Brute Force Attack

→ **Ataque de fuerza bruta.**

Consiste en intentar muchas contraseñas hasta acertar.

Ataques de inyección

El atacante **introduce código** malicioso en una aplicación que no valida correctamente la entrada del usuario.

Inyección SQL (SQLi)

Inserción de **código SQL** malicioso en inputs (formularios, URLs, etc.) para alterar consultas a la base de datos.

Tipos:

- **In-band SQLi (SQLi en banda o clásico):**
El tipo más común. El atacante usa el mismo canal para enviar y recibir datos.
- **Out-of-band SQLi (Fuera de banda):**
El ataque se lanza desde un canal alternativo al que recibe los resultados.
- **Inferential or Blind SQLi (SQLi ciego):**
El atacante no recibe respuesta directa pero infiere información en base al comportamiento del sistema.

Ejemplos:

- **Error-based SQLi (Basado en errores):**
Se explotan mensajes de error del sistema para obtener información.
- **Union-based SQLi (Basado en UNION):**
Uso de **UNION** para combinar resultados legítimos con datos extraídos.
- **Boolean-based (Basado en verdadero/falso):**
Se envían condiciones y se observa si la respuesta cambia.
- **Time-based (Basado en tiempo):**
Se usan retrasos (ej. **SLEEP**) para inferir resultados.

XSS (Cross-Site Scripting)

Inyección de **scripts** (generalmente JavaScript) en páginas web vistas por otros usuarios, para robar cookies, secuestrar sesiones o modificar contenido.

Tipos:

- **Stored XSS (Persistente):**
El script se guarda en el servidor (ej. base de datos) y afecta a múltiples usuarios.
- **Reflected XSS (Reflejado):**
El script se envía en una solicitud (ej. URL) y se refleja inmediatamente en la respuesta.
- **DOM-based XSS:**
La vulnerabilidad está en el manejo del DOM en el navegador, no en el servidor.

Cryptojacking

Es el uso no autorizado del dispositivo de una víctima para **minar criptomonedas**.

El atacante instala malware o usa scripts en el navegador, y el dispositivo de la víctima realiza cálculos para generar criptomonedas sin su consentimiento.

Indicadores comunes de cryptojacking son:

- Uso elevado de CPU/GPU.
- Dispositivo lento o sobrecalentado.
- Mayor consumo de batería.

Suplantación de IP (IP Spoofing)

Técnica que consiste en **falsificar la dirección IP** de origen para hacerse pasar por otro dispositivo.

- Se puede enviar tráfico con una IP falsa sin esperar respuesta (ej: ataque DoS).
- Se puede intentar interceptar tráfico y recibir respuesta (ej: Man-in-the-Middle).

Denial of Service (DoS)

Ataque que busca hacer que un sistema, red o servicio deje de estar disponible para usuarios legítimos.

- Se logra **sobrecargando** el sistema con tráfico o solicitudes.
- Objetivo: **interrumpir el servicio**, no necesariamente robar datos.

Tipos:

- **Distribuido (DDoS – Distributed Denial of Service):**
Se hace desde muchos dispositivos (botnet) y es más potente.
- **Volumétrico:** Satura el ancho de banda con tráfico masivo.
- **De protocolo:** Explota debilidades en protocolos de red. Ej: SYN flood.
- **De capa de aplicación:** Atacan servicios específicos (HTTP, APIs).
Ejemplo: muchas requests a una web.

SYN flood

El **protocolo TCP** (Transmission Control Protocol) permite que dos dispositivos se comuniquen de forma confiable, asegurando que los datos lleguen correctamente.

Para iniciar una conexión entre dos dispositivos, se utiliza un tipo de mensaje llamado **SYN**.

El ataque de tipo **SYN flood** es cuando se envían muchos mensajes SYN pero nunca se completa y cierra la conexión.

El servidor se queda esperando respuestas que no llegan y se satura, dejando de responder a usuarios reales.

Smurf attack

El **protocolo ICMP** (Internet Control Message Protocol) permite controlar el estado de una red.

Un **ping** es una herramienta del protocolo que se utiliza para comprobar si un dispositivo está disponible (se envía un *echo request* y se espera un *echo reply*).

En un **smurf attack**, el atacante suplanta la IP de la víctima y envía un ping a muchas máquinas, haciendo que todas respondan a la víctima en avalancha y la saturen.

Packet Sniffing

Técnica que consiste en **interceptar y analizar** los paquetes de datos que circulan por una red.

Tipos:

- **Pasivo:** Solo observa la información en los paquetes sin modificar nada. Funciona en redes donde los datos se transmiten a todos (ej: hub o WiFi abierto).
- **Activo:** Interviene en la red para capturar paquetes y puede redirigir los datos a otros dispositivos.

Usos:

- **No maliciosos:** Diagnóstico de red (detectar fallos), monitoreo de tráfico, seguridad (detectar ataques).
- **Maliciosos:** Robo de contraseñas o datos sensibles, espionaje de comunicaciones, intercepción de sesiones (session hijacking).

Man-in-the-Middle (MitM)

Ataque en el que **un tercero se interpone** entre dos dispositivos que se están comunicando. Puede escuchar, interceptar o modificar la información sin que las partes lo noten.

Permite espiar datos (contraseñas, mensajes), alterar la comunicación y/o suplantar a una de las partes.

Actualmente se le llama **On-path attack**.

Glosario de amenazas y ataques

- **Advanced Persistent Threat (APT) – Amenaza persistente avanzada:**
Situación en la que un actor malicioso mantiene acceso no autorizado a un sistema durante un período prolongado.
- **Attack surface – Superficie de ataque:**
Conjunto de todas las posibles vulnerabilidades que un atacante podría explotar.
- **Attack tree – Árbol de ataque:**
Diagrama que mapea amenazas hacia activos.
- **Attack vector – Vector de ataque:**
Vías o métodos que los atacantes utilizan para penetrar las defensas.
- **Botnet – Red de bots:**
Conjunto de computadoras infectadas con malware que están bajo el control de un mismo atacante (bot-herder).

- **Dropper – Instalador de malware:**
Tipo de malware que contiene código malicioso y lo entrega e instala en un sistema objetivo.
- **Fileless malware – Malware sin archivos:**
Malware que no necesita instalación porque utiliza programas legítimos ya presentes en el sistema para infectarlo.
- **Internet Control Message Protocol (ICMP) – Protocolo de Mensajes de Control de Internet:**
Protocolo usado por dispositivos para comunicarse errores o estado de la transmisión de datos en la red.
- **Internet Control Message Protocol (ICMP) flood – Inundación ICMP:**
Tipo de ataque DoS en el que un atacante envía repetidamente paquetes ICMP a un servidor.
- **Loader – Cargador de malware:**
Tipo de malware que descarga código malicioso desde una fuente externa y lo instala en el sistema objetivo.
- **Packet capture (p-cap) – Captura de paquetes:**
Archivo que contiene paquetes de datos interceptados de una red o interfaz.
- **Phishing kit:**
Conjunto de herramientas de software necesarias para lanzar una campaña de phishing.
- **Ping of death – Ping de la muerte:**
Tipo de ataque DoS en el que se envía un paquete ICMP de tamaño excesivo (mayor a 64KB) para colapsar un sistema.
- **Potentially unwanted application (PUA) – Aplicación potencialmente no deseada:**
Software no deseado que suele venir incluido con programas legítimos y puede mostrar publicidad, ralentizar el sistema o instalar otros programas.
- **Replay attack – Ataque de repetición:**
Ataque en el que un atacante intercepta un paquete de datos y lo retransmite o retrasa para reutilizarlo en otro momento.
- **Rootkit:**
Malware que proporciona acceso remoto con privilegios administrativos a un sistema.
- **Watering hole attack – Ataque de abrevadero:**
Ataque en el que se compromete un sitio web frecuentado por un grupo específico de usuarios.

Ciberseguridad

Activos (Assets)

Son todos los **elementos de valor** para una organización (información, hardware, software, personas).

Pueden tener vulnerabilidades ante amenazas y ataques.

- **Vulnerabilidades:** Debilidades que pueden ser explotadas por amenazas.
- **Amenazas:** Posibles peligros que pueden afectar a los activos.
- **Ataques:** Acciones que explotan vulnerabilidades para causar daño o robo.

Datos

Información que puede ser almacenada, procesada o transmitida.

- **Datos en uso (in use):** Datos que están siendo accedidos por un usuario o siendo activamente procesados en memoria o CPU.
- **Datos en tránsito (in transit):** Datos que están siendo enviados por redes, cables o internet.
- **Datos en reposo (at rest):** Datos almacenados en discos, bases de datos o backups, que no están ni en uso ni en tránsito.

PII (Personally Identifiable Information)

→ **Información Personal Identificable.**

Son los datos que pueden identificar directa o indirectamente a una persona. Están protegidos por leyes de privacidad.

Ejemplos: nombre completo, DNI, correo electrónico, teléfono, dirección.

SPII (Sensitive Personally Identifiable Information)

→ **Información Personal Sensible.**

Subconjunto de PII que, si se expone, puede causar daño directo o riesgo alto a la persona. Requieren medidas de protección más estrictas.

Ejemplos: número de tarjeta de crédito, historial médico, número de seguridad social, huellas biométricas.

Packets

Un **paquete de datos** (packet) es la unidad básica de transmisión en redes. Al enviar información, esta se fragmenta en múltiples paquetes que viajan de forma independiente por la red y luego se reensamblan en destino.

Partes:

- **Header (cabecera):**
Contiene la metadata necesaria para enrutar y procesar el paquete.
Ej: dirección de origen, dirección de destino, protocolo, número de secuencia para ordenar los paquetes en el destino.
- **Payload (data):**
Es el contenido útil del paquete, los datos reales a transmitir.
- **Footer (cola o trailer):**
Indica el final del paquete y sirve para validar su integridad.

Autenticación

Es el proceso de **verificar la identidad** de un usuario (ej: contraseña, biometría).

Algunas formas populares:

- **Single Sign-On (SSO) – Inicio de sesión único:**
permite acceder a múltiples sistemas con una sola autenticación.
Ejemplo: iniciar sesión con la cuenta de Google en otras plataformas.
- **Multi-Factor Authentication (MFA) – Autenticación multifactor:**
requiere que el usuario verifique su identidad mediante dos o más métodos (algo que sabe, tiene o es) para acceder a un sistema o red.
Ejemplo: contraseña + recibir mensaje de texto con código.

CAPTCHA

CAPTCHA significa **C**ompletely **A**utomated **P**ublic **T**uring test to tell **C**omputers and **H**umans **A**part (prueba de Turing pública completamente automatizada para diferenciar humanos de computadoras).

Consiste en pedir a los usuarios que completen una prueba simple que demuestre que son humanos. Esto ayuda a prevenir que programas intenten realizar ataques de fuerza bruta sobre contraseñas.

reCAPTCHA es un servicio gratuito de CAPTCHA de Google que ayuda a proteger sitios web contra bots y software malicioso.

Criptografía

Es la ciencia de **proteger información** mediante técnicas de cifrado, para garantizar:

- **Confidencialidad (Confidentiality):**
que solo las personas autorizadas puedan acceder a la información.
- **Integridad (Integrity):**
que la información no haya sido modificada sin autorización.
- **Autenticidad (Authenticity):**
que se pueda verificar que la información o el remitente son genuinos.

- **No repudio (Non-repudiation):**

que quien envió un mensaje no pueda negar haberlo enviado. Se usa mucho en firmas digitales y transacciones electrónicas.

Cifrado

La **encriptación** (encryption) o cifrado consiste en transformar datos legibles (plaintext / texto plano) en ilegibles (ciphertext / texto cifrado).

Claves

Las **keys** (llaves o claves) son información secreta usada para cifrar o descifrar datos.

Tipos de claves:

- **Symmetric key (Clave simétrica):**

Una misma clave sirve tanto para cifrar como para descifrar.

- Ventajas: Rápido, eficiente para grandes volúmenes de datos.
- Desventajas: Cómo compartir la clave de forma segura.

- **Asymmetric key (Clave asimétrica / criptografía de clave pública):**

Se usa un par de claves diferentes para cifrar y descifrar.

- **Public key (Clave pública):** para cifrar, se comparte abiertamente.
- **Private key (Clave privada):** para descifrar, se mantiene secreta.
- Ventajas: No requiere compartir la clave secreta, más seguro para comunicaciones abiertas.
- Desventajas: Más lento que la criptografía simétrica.

Hashing

Un Hash (Función hash / resumen criptográfico) es un algoritmo que transforma un mensaje de cualquier tamaño en un valor fijo, llamado **hash o digest**.

Características:

- **Unidireccional:** no se puede “deshacer” para obtener el mensaje original.
- **Determinístico:** mismo mensaje → mismo hash.
- **Sensibilidad:** cambio mínimo en el mensaje → hash completamente diferente.

Usos:

- Verificar **integridad de datos** (si el hash cambia, el mensaje fue alterado).
- Almacenamiento seguro de contraseñas.

Servicios en la nube (Cloud-based services)

Servicios accesibles **por internet** en lugar de instalarse localmente.

Permiten usar almacenamiento, aplicaciones y procesamiento sin tener infraestructura propia.

Software as a Service (SaaS)

- **Aplicaciones** completas lista para usar en la nube.
- No requiere instalación ni mantenimiento por parte del usuario.
- Ejemplos: Gmail, Google Docs, Slack.

Platform as a Service (PaaS)

- Plataforma en la nube para desarrollar, probar y desplegar aplicaciones.
- Incluye herramientas y **entornos de desarrollo**, pero no el hardware.
- Ejemplos: Google App Engine, Heroku.

Infrastructure as a Service (IaaS)

- Infraestructura básica en la nube: **servidores, almacenamiento y redes**.
- Permite construir y gestionar sistemas completos sin comprar hardware físico.
- Ejemplos: Amazon EC2, Microsoft Azure Virtual Machines.

Máquinas virtuales (VMs)

Las máquinas virtuales (VMs) son **versiones de software de computadoras físicas**. Proporcionan una capa adicional de seguridad para una organización, ya que pueden utilizarse para **ejecutar código en un entorno aislado**, evitando que código malicioso afecte al resto del sistema.

Las VMs también pueden eliminarse y reemplazarse por una imagen limpia después de probar malware.

Hypervisors

Son softwares que permiten **crear y gestionar** máquinas virtuales (VMs). Controlan cómo las VMs utilizan los recursos del hardware.

Tipos:

- **Tipo 1 (bare-metal):** Se ejecutan directamente sobre el hardware (ej: servidores). Son más eficientes y seguros.
- **Tipo 2 (hosted):** Se ejecutan sobre un sistema operativo, son más fáciles de usar.

SIEM (Security Information and Event Management)

Herramientas que **recopilan, analizan y monitorean eventos de seguridad** de múltiples sistemas en un solo lugar.

- Recolectan logs de dispositivos, servidores, redes y aplicaciones
- Detectan actividades sospechosas
- Generan alertas en tiempo real
- Permiten análisis e investigación de incidentes para dar respuesta rápida

Logs

Son **registros** automáticos que guardan eventos y actividades de un sistema. Es como el historial de lo que pasa en un sistema o red.

Formatos comunes para logs: JSON, Syslog, XML, CSV.

Evento vs. Incidente

- **Event (Evento):**
Ocurrencia observable en una red, sistema o dispositivo.
- **Incident (Incidente):**
Evento que compromete o amenaza comprometer la confidencialidad, integridad o disponibilidad de la información o sistemas, o viola políticas o leyes de seguridad.

Detección y respuesta (incidentes)

Conceptos clave:

- **Computer Security Incident Response Teams (CSIRT) – Equipos de respuesta a incidentes de seguridad informática:**
Grupo especializado de profesionales de seguridad capacitados en gestión y respuesta a incidentes.
- **Endpoint Detection and Response (EDR) – Detección y respuesta en endpoints:**
Aplicación que monitorea un endpoint en busca de actividad maliciosa.
- **Intrusion Detection System (IDS) – Sistema de detección de intrusiones:**
Aplicación que monitorea la actividad del sistema y alerta sobre posibles intrusiones.
- **Intrusion Prevention System (IPS) – Sistema de prevención de intrusiones:**
Aplicación que monitorea actividad maliciosa y toma acciones para detenerla.
- **NIST Incident Response Lifecycle – Ciclo de respuesta a incidentes de NIST:**
Marco con cuatro fases: Preparación; Detección y análisis; Contención, erradicación y recuperación; Actividades posteriores al incidente.
- **Security Operations Center (SOC) – Centro de operaciones de seguridad:**
Unidad organizacional dedicada a monitorear redes, sistemas y dispositivos en busca de amenazas.
- **Security Orchestration, Automation, and Response (SOAR) – Orquestación, automatización y respuesta de seguridad:**
Conjunto de herramientas y flujos que automatizan la respuesta a eventos de seguridad.

Categorías de detección

- **True positive (Verdadero positivo):**
Alerta que detecta correctamente la presencia de un ataque.
- **True negative (Verdadero negativo):**
Situación en la que no hay detección de actividad maliciosa porque realmente no existe.
- **False positive (Falso positivo):**
Alerta que detecta incorrectamente la presencia de una amenaza.
- **False negative (Falso negativo):**
Situación en la que no se detecta una amenaza que sí está presente.

Documentación

Es cualquier forma de **contenido registrado** utilizado con un propósito específico.

- **Playbook – Guía operativa / manual de procedimientos:**
Documento que detalla cómo actuar ante situaciones específicas.
- **Plan de respuesta a incidentes:**
Documento que define los procedimientos a seguir en cada etapa de la respuesta.
- **Incident handler's journal – Registro del analista de incidentes:**
Forma de documentación utilizada en la respuesta a incidentes.

Glosario de ciberseguridad

- **Access controls – Controles de acceso:**
Controles de seguridad que gestionan el acceso, la autorización y la responsabilidad sobre la información.
- **Application programming interface (API) token – Token de API:**
Pequeño bloque de código cifrado que contiene información sobre un usuario.
- **Asset classification – Clasificación de activos:**
Práctica de etiquetar activos según su sensibilidad e importancia.
- **Asset inventory – Inventario de activos:**
Catálogo de activos que necesitan protección.
- **Asset management – Gestión de activos:**
Proceso de rastrear activos y los riesgos que los afectan.
- **Baseline configuration (baseline image) – Configuración base (imagen base):**
Conjunto documentado de especificaciones de un sistema que se utiliza como referencia para futuras construcciones, versiones y actualizaciones.

- **Basic auth – Autenticación básica:**
Tecnología utilizada para establecer la solicitud de acceso de un usuario a un servidor.
- **Bug bounty – Programa de recompensas por bugs:**
Programas que incentivan a hackers independientes a encontrar y reportar vulnerabilidades.
- **Cipher – Algoritmo de cifrado:**
Algoritmo que cifra información.
- **Common Event Format (CEF):**
Un formato para logs que usa pares clave-valor para estructurar datos e identificar campos y sus valores correspondientes.
- **Common Vulnerabilities and Exposures (CVE) list – Lista CVE:**
Diccionario público de vulnerabilidades y exposiciones conocidas.
- **Common Vulnerability Scoring System (CVSS) – Sistema de puntuación de vulnerabilidades:**
Sistema que mide la gravedad de una vulnerabilidad.
- **Compliance – Cumplimiento:**
Proceso de seguir normas internas y regulaciones externas.
- **CVE Numbering Authority (CNA) – Autoridad de numeración CVE:**
Organización que analiza y distribuye información sobre vulnerabilidades CVE.
- **Data custodian – Custodio de datos:**
Persona o sistema responsable del manejo, transporte y almacenamiento seguro de la información.
- **Data owner – Propietario de datos:**
Persona que decide quién puede acceder, modificar, usar o eliminar su información.
- **Digital certificate – Certificado digital:**
Archivo que verifica la identidad del titular de una clave pública.
- **Hash collision – Colisión de hash:**
Situación en la que diferentes entradas producen el mismo valor hash.
- **Hash table – Tabla hash:**
Estructura de datos utilizada para almacenar y referenciar valores hash.
- **Identity and access management (IAM) – Gestión de identidades y accesos:**
Conjunto de procesos y tecnologías para gestionar identidades digitales.
- **Information security (InfoSec) – Seguridad de la información:**
Práctica de proteger los datos en todos sus estados de accesos no autorizados.

- **Intrusion Detection System (IDS) – Sistema de detección de intrusiones:**
Aplicación que monitorea la actividad del sistema y alerta sobre posibles intrusiones.
- **National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) – Marco de ciberseguridad del NIST:**
Marco voluntario de normas, guías y buenas prácticas para gestionar riesgos de ciberseguridad.
- **Network log analysis – Análisis de logs de red:**
Proceso de examinar registros de red para identificar eventos relevantes.
- **OAuth:**
Protocolo estándar abierto de autorización que permite compartir acceso entre aplicaciones.
- **Patch update – Actualización de parche:**
Actualización de software o sistema operativo que corrige vulnerabilidades de seguridad en un programa o producto.
- **Payment Card Industry Data Security Standards (PCI DSS) – Estándares de seguridad de datos de la industria de tarjetas de pago:**
Conjunto de estándares de seguridad del sector financiero.
- **Penetration testing (pen test) – Prueba de penetración:**
Ataque simulado que ayuda a identificar vulnerabilidades en sistemas, redes, sitios web, aplicaciones y procesos.
- **Policy – Política:**
Conjunto de reglas que reducen riesgos y protegen la información.
- **Prepared statement – Sentencia preparada:**
Técnica de programación que ejecuta sentencias SQL de forma segura antes de enviarlas a la base de datos.
- **Principle of least privilege – Principio de mínimo privilegio:**
Otorgar solo el acceso mínimo necesario para realizar una tarea.
- **Procedures – Procedimientos:**
Instrucciones paso a paso para realizar una tarea de seguridad específica.
- **Process of Attack Simulation and Threat Analysis (PASTA) – Proceso de simulación de ataques y análisis de amenazas:**
Marco de modelado de amenazas ampliamente utilizado en distintas industrias.
- **Protected health information (PHI) – Información de salud protegida:**
Datos sobre la salud física o mental de una persona.
- **Public key infrastructure (PKI) – Infraestructura de clave pública:**
Marco de cifrado que asegura el intercambio de información en línea.

- **Rainbow table – Tabla arcoíris:**
Archivo con hashes pre-generados y sus textos originales asociados.
- **Regulations – Regulaciones:**
Reglas establecidas por un gobierno u otra autoridad para controlar cómo se realiza algo.
- **Risk – Riesgo:**
Cualquier cosa que pueda afectar la confidencialidad, integridad o disponibilidad de un activo.
- **Salting:**
Técnica que añade datos extra para fortalecer funciones hash.
- **Security assessment – Evaluación de seguridad:**
Análisis para medir la resistencia de sistemas ante amenazas.
- **Security audit – Auditoría de seguridad:**
Revisión de controles, políticas y procedimientos de seguridad.
- **Security controls – Controles de seguridad:**
Medidas diseñadas para reducir riesgos específicos.
- **Security hardening – Endurecimiento de seguridad:**
Proceso de fortalecer un sistema para reducir vulnerabilidades y superficie de ataque.
- **Separation of duties – Separación de funciones:**
Principio que evita otorgar permisos que permitan abusos del sistema.
- **Session – Sesión:**
Secuencia de solicitudes y respuestas HTTP asociadas a un usuario.
- **Session cookie – Cookie de sesión:**
Token que valida una sesión y su duración.
- **Session hijacking – Secuestro de sesión:**
Ataque donde se obtiene el ID de sesión de un usuario legítimo.
- **Session ID – ID de sesión:**
Token único que identifica a un usuario y su dispositivo.
- **Standards – Estándares:**
Referencias que indican cómo establecer políticas.
- **User provisioning – Aprovisionamiento de usuarios:**
Proceso de crear y mantener identidades digitales de usuarios.
- **World-writable file – Archivo con permisos de escritura global:**
Archivo que puede ser modificado por cualquier usuario.

- **Zero-day – Vulnerabilidad de día cero / exploit de día cero:**
Vulnerabilidad desconocida previamente y sin parche disponible.

Lenguajes de programación en ciberseguridad

SQL

SQL (Structured Query Language) se usa principalmente para interactuar con **bases de datos**.

Usos **legítimos** en ciberseguridad:

- **Auditoría de bases de datos:** Revisar registros, accesos y cambios para detectar actividades sospechosas.
- **Gestión de datos de seguridad:** Consultar logs, usuarios, permisos o incidentes almacenados en bases de datos.
- **Pruebas de penetración controladas:** Testear la seguridad de bases de datos en entornos autorizados.

Usos **maliciosos**: **Inyección SQL (SQLi)**.

- **Explotación de vulnerabilidades:** Un atacante inserta comandos SQL en formularios o URLs para acceder, modificar o borrar datos de forma no autorizada.
- **Robo de información:** Obtener contraseñas, datos personales o financieros.
- **Manipulación de registros:** Cambiar o eliminar información crítica de la base de datos.

JavaScript

JavaScript es un lenguaje de programación interpretado, orientado a eventos, que se ejecuta principalmente en el **navegador** del usuario (cliente), aunque también puede correr en **servidores** (por ejemplo con Node.js).

Es el lenguaje dominante para la lógica de **aplicaciones web**, lo que lo convierte en un **vector de ataque** crítico, porque:

- Se ejecuta directamente en el navegador del usuario.
- Tiene acceso al DOM, cookies, almacenamiento local, etc.
- Interactúa constantemente con servidores (APIs).

Usos **legítimos** en ciberseguridad:

- **Validación de inputs (frontend)**
 - Filtrado básico de datos antes de enviarlos al servidor
 - Mejora de UX y reducción de tráfico inválido

- **Implementación de controles de seguridad en cliente**
 - Sanitización y escaping para mitigar Cross-Site Scripting (XSS)
 - Integración con políticas como CSP
- **Monitoreo y detección en el navegador**
 - Scripts para detectar comportamientos sospechosos (ej. actividad anómala)
 - Instrumentación de eventos (clicks, inputs)
- **Desarrollo de herramientas de pentesting**
 - Automatización de testing en apps web
 - Simulación de ataques (XSS, requests maliciosos)
 - Uso en navegadores headless
- **Análisis y reverse engineering**
 - Inspección de código JS para encontrar vulnerabilidades
 - Deofuscación de scripts sospechosos
- **Interacción segura con APIs**
 - Manejo de autenticación (tokens, headers)
 - Validación de respuestas

Usos maliciosos:

- **Cross-Site Scripting (XSS)**
 - Inyección de scripts en páginas legítimas
 - Ejecución en el navegador de la víctima
- **Robo de información**
 - Exfiltración de cookies, tokens, datos de formularios
 - Keylogging en el navegador
- **Manipulación del DOM**
 - Alteración de formularios (phishing)
 - Inserción de contenido falso o malicioso
- **Automatización de ataques web**
 - Envío de requests autenticados (relacionado con Cross-Site Request Forgery)
 - Fuerza bruta desde el cliente
- **Malware basado en navegador**
 - **Cryptojacking**
 - Descarga/ejecución de payloads adicionales
- **Evasión y ofuscación**
 - Código ofuscado para evitar detección
 - Uso de técnicas dinámicas (eval, loaders remotos)

Python

Python es un lenguaje de programación interpretado, de alto nivel, con sintaxis clara y gran cantidad de librerías. Se ejecuta tanto en servidores como en PCs locales, y es muy usado en **automatización, análisis de datos** y desarrollo de herramientas de seguridad.

Usos de Python en ciberseguridad:

■ Defensa (seguridad defensiva)

- **Análisis de logs** → Automatización de lectura y filtrado de registros de sistemas o firewalls.
- **Monitoreo de red** → Captura y análisis de paquetes (packet sniffing, escaneo de tráfico).
- **Automatización de tareas de seguridad** → Backups, actualizaciones de firmas de antivirus, verificación de configuraciones.
- **Desarrollo de herramientas de auditoría interna** → Scripts para comprobar configuraciones seguras, vulnerabilidades conocidas.

■ Pentesting y pruebas ofensivas

- **Escaneo y enumeración de redes** → Escaneo de puertos, descubrimiento de hosts, análisis de servicios.
- **Explotación de vulnerabilidades** → Scripts para SQLi, XSS, CSRF (complementario con aplicaciones web).
- **Fuzzing y testing de aplicaciones** → Envío masivo de inputs para probar estabilidad y seguridad de apps.
- **Automatización de ataques** → Automatizar ataques de fuerza bruta, phishing, scraping de datos.

■ Análisis forense y malware

- **Análisis de malware** → Descompilación, análisis de comportamiento, extracción de indicadores.
- **Decodificación de datos y criptografía** → Scripts para descryptar o analizar datos comprometidos.